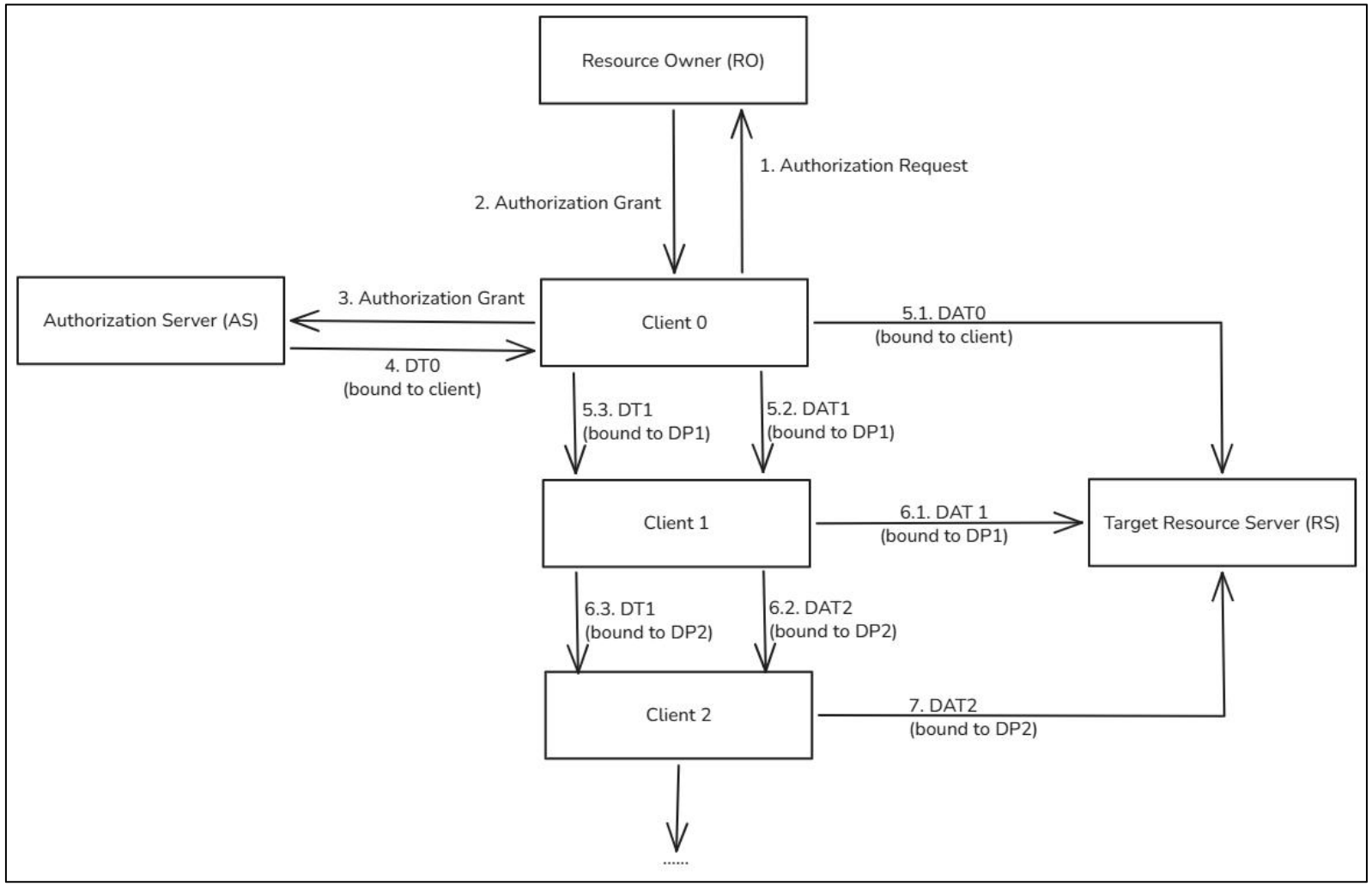
OAuth Delegated Authorization

draft-li-oauth-delegated-authorization

Ruochen Li, *Haiguang Wang, Chunchi Peter Liu, Tieyan Li*
Huawei

Delegated Authorization – Protocol Flow



- Top-level client gets a **delegation token (DT)** from AS
- **DTs** can be used to issue subordinate **DTs** or **delegated access tokens (DAT)**
- Only **DATs** can be used to access RS
- **DTs/DATs** can be delegated to other clients (MUST be sender-constrained)
- A client that receives a **DT** (from AS or another client) can use it to generate **DTs/DATs** delegated to other clients or generate **DATs** for accessing RS

At step 5, Client 0 may perform any of the following actions:

- Generate a DAT for itself to access RS
- Generate a DAT for client 1, allowing client 1 to access RS
- Generate a DT for client 1, allowing client 1 to delegate authorization to others

Same goes for steps 6 & 7.

Delegated Authorization – Token Format (JWT)

Top-Level Delegation Token


```
{
  "protected": {
    "_comment": "to be base64url-encoded",
    "alg": "RS256",
    "typ": "JWT",
    "kid": "as-key-2"
  },
  "payload": {
    "_comment": "to be base64url-encoded",
    "iss": "https://as1.example.com",
    "sub": "user@example.com",
    "aud": "https://res1.example.com",
    "iat": 1772177588,
    "exp": 1774769588,
    "scope": "email:read email:write email:send",
    "delegation_key": {
      "kty": "RSA",
      "n": "3O1EVa-
_zsENOhylq99puKjF6NBq8S8Ntw9sufyCB9LrTSs-
xRoDQ7X6rYbPEOn5E-
6ASZyUW2vFxLacj0Wir05hznlnfRLRTmJhud4im5COfAhuiPeL
0Mbs3WFLdBfWVGXSP2O5UNkd7dJ2KqudqxNF81Nrt51RpmPR59
pUZS3REfAYgtqhQ07WuCTzd2VpFttPFurDSiWcriyELNdgsT9w
ap0nyceSVLQgY9ZgR0VvsmHj_LUKie1t5RCjTsaMHJH6x3QI0t
jKG9Psbil0ORlhA9WEgOO6E6KOC_StEBnK_Ntb2ArGPDjlNPzT
qWOeeev84MM8VXdRzpTLOrRmHQ",
      "e": "AQAB"
    },
    "max_delegation_depth": 3
  },
  "signature":
"p1OjJQ2tASuFPPCXzdbuSHaZiPTF2jM1Z_My2_qPx0IAAJJ5R
Vo9Km2hFeXjqqGcjkG5wEFxMw_q8JO48O9bVaKNBa1k_-
UoBxf5KlMpldMFIUyV4D8Sugshh73iqVii5HW2MY4uS5Gj46GD
UcX1NQRg8LW6Wa4zso0SPfIfunXF0dvBG24cCUoIFOr1NzryZ7
OcVt9kdC4_uXGoSmjtGl1XsRvgb216fZFuZV0F88zWFsDcBZn4
i8qGcBS2XAHjW4jbH7Y1O8dvl2h0afftmNkG2ZgHPl3phj_i-
unQsAxhCUI_8MjtfF5iwe586uQw_1iED2IUlEXOgX-Ld5GgTw"
}
```


Subordinate Delegation Token


```
{
  "protected": {
    "_comment": "to be base64url-encoded",
    "alg": "RS256",
    "typ": "JWT",
    "kid": "delegation-key-2"
  },
  "payload": {
    "_comment": "to be base64url-encoded",
    "aud": "https://res1.example.com",
    "iat": 1772181188,
    "exp": 1772782388,
    "max_delegation_depth": 1,
    "scope": "email:read email:write",
    "delegationToken":
"eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImFzL
WtleS0yIn0..."
  },
  "signature":
"lnf8Wz5M_B4dVTOOjT0aQa0ZSqEbTZVGb1HU_dk1tJ4eCbkCB
8lmO0wJXc07Ys8gKqqb3TS4tKUbnwwKo3_Dw3FGYjbDqDE7rBt
dc0lqi6fKSecff2ujVCi2U2dLjX78_h7U0LP1XbJuhkjdBYa-
_mwiygAXf0j8cilXTigbTWJfgqcziVmkJzl9a_5HJ8HYF5ohdG
mVBhOfyRrwGikYoHEQB6Ye_6jwTD_IQsUJe0eYdD4xAdA7C2aw
ZAvhdYduKXit7WSyGuEhbyKopsm6WVZz4BkjWDjcJ2S7Xjb6Rx
PCGc_nNiAMsGT1nG9MIj-oGYy8gIWPSLEyF_6sk8hiaQ"
}
```

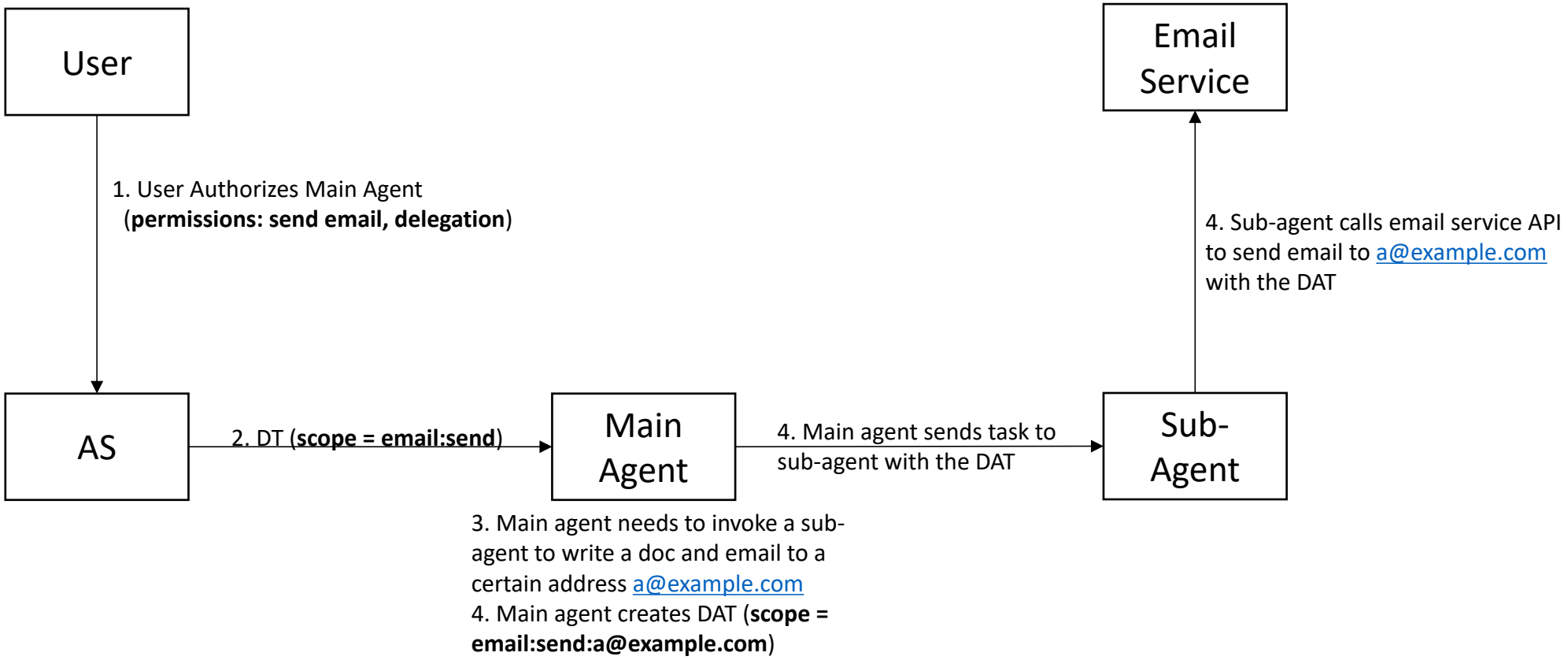

Delegated Access Token


```
{
  "protected": {
    "_comment": "to be base64url-encoded",
    "alg": "RS256",
    "typ": "JWT",
    "kid": "delegation-key-2-sub"
  },
  "payload": {
    "_comment": "to be base64url-encoded",
    "sub": "https://dp1.example.com",
    "aud": "https://res1.example.com",
    "iat": 1772184788,
    "exp": 1772188388,
    "scope": "email:read",
    "delegationToken":
"eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6ImRlb
GVnYXRpb24ta2V5LTIifQ..."
  },
  "signature": "mn-0y0F3lx0IM-
60UsBp1_M7uRhdT28dPqxt6-s1OnjM-obyF-
p5XbQV9jI5Q56X4cb3jLl6RkM789ODTGt5y4QNdOA2WhlS0Wld
SOzYkV1Xj2yrC0mZakYCHTpzzgvfeUjeNj-
fDWmtgRb2Lfm6Z6dguT071WQkaIyH4IW5xVxroqbn1tFM07uX3
huIV9tC_iS926rWaDW7eQDm1nhhjS_QSgUcTF1eJy7hOjEtzs7
0iij5bQU-
B9nn6OfXdpb1jO5vx3lCSnZfL2h2EaQYK3CbjrflbDnIYKtJ0N
Mx5D03KRcv_uPlG5HHRL5cuMz8eToKc08rc0Qs5PxDbeqV4A"
}
```


Similarly, CWT, etc. can also be used.

Delegated Authorization

- Similar to PKI certs (but for authz instead of authn)
- Verification involves the whole token chain
- Delegation happens locally, does not go through AS (STS) ➡ ↑ privacy, ↓ AS load, ↓ network traffic
- Only down-scoping is allowed
  - all claims inherited from parent DT (e.g. scope must be a subset of the parent DT)
  - new claims not allowed (except delegation specific claims e.g. max_delegation_depth)

- Supports authorization code grant, etc.
- Supports RAR (Rich Authorization Request) in addition to scope
- Supports RS local verification of DAT & token introspection
- Supports on-demand token generation in response to (not yet specified in the draft)
  - 401 with WWW-Authenticate
  - Step-up authorization challenge

Delegated Authorization – Use In AI Agents